

Informed Consent – User Study “Ontwikkeling van een gebruiksvriendelijke security modellering applicatie gebaseerd op fortunately/unfortunately methode”

Titel studie: Evaluatie van dreigingsmodellering applicatie

Onderzoeker: *Mika Gielkens*

Contact: *mika.gielkens@student.uhasselt.be*

Doel van het onderzoek

U wordt uitgenodigd om deel te nemen aan een studie die onderzoekt hoe softwaregebruikers security- en AI-risicoscenario's analyseren met behulp van een “Fortunately–Unfortunately”-model. Uw deelname helpt ons om de bruikbaarheid, helderheid en efficiëntie van de software te evalueren en te verbeteren.

Wat houdt deelname in?

Als u deelneemt:

- Voert u enkele praktische scenario-taken uit binnen de software. Dit scenario bevat 4 uit te voeren taken.
- Evalueert u de software via een korte vragenlijst.

Uw deelname is volledig vrijwillig.

Demografische gegevens

Leeftijd: _____

Opleiding: _____

Ervaring met security: Ja/nee

Ervaring met security modellering: Ja/nee

Licht kort toe: _____

Huidige functie: : _____

Risico's en ongemakken

Het onderzoek brengt **geen bekende risico's** met zich mee. U kunt op elk moment pauzeren of stoppen zonder gevolgen.

Privacy & vertrouwelijkheid

- Alle verzamelde gegevens zullen **gepseudonimiseerd** worden om de privacy van de deelnemers te beschermen..
- Er worden **geen persoonsgegevens** (zoals naam, e-mail of IP-adres) gekoppeld aan uw antwoorden.
- Het scherm van het gebruikte toestel zal worden opgenomen zodat dit later kan teruggekeken worden ten behoeve van het onderzoek. Deze opname zal ook live worden gevolgd door de masterstudent via een tweede scherm.
- Uw gegevens worden uitsluitend gebruikt voor onderzoeksdoeleinden en niet gedeeld met derden buiten het onderzoeksteam.

Vrijwillige deelname & recht om te stoppen

Uw deelname is vrijwillig.

U mag op elk moment:

- verdere deelname weigeren, of
- het onderzoek stopzetten

...zonder dat u hiervoor een reden moet opgeven. Uw gegevens worden bij stopzetting verwijderd.

Gebruik van resultaten

De resultaten kunnen worden gebruikt in:

- onderzoeksrapporten
- academische publicaties
- interne evaluaties

De data zal niet gelinked worden aan uw naam maar aan een ID zodat u later kan vragen deze data te verwijderen.

Toestemming

Door hieronder akkoord te gaan, bevestigt u dat:

- u de informatie hierboven hebt gelezen,
- u begrijpt wat deelname inhoudt,
- uw deelname volledig vrijwillig is, en
- u toestemming geeft om uw anonieme gegevens te gebruiken voor dit onderzoek.

☐ **Ik ga akkoord met deelname aan deze studie.**

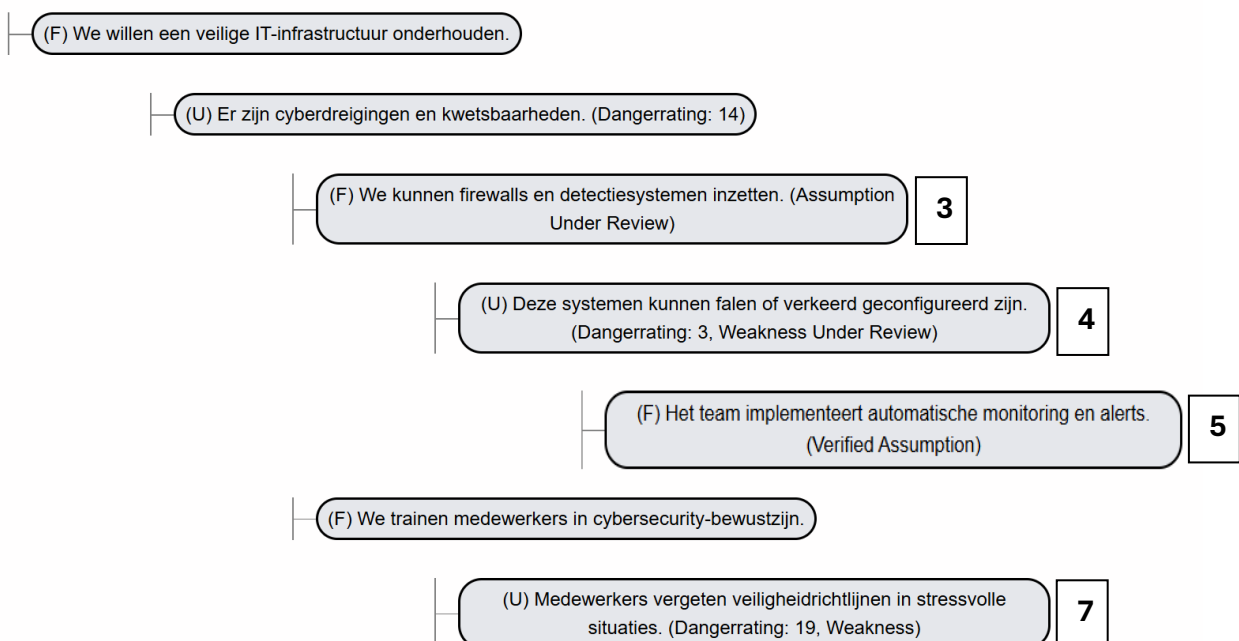
Naam:

Handtekening:

Uitleg *Fortunately–Unfortunately*-methode

De *Fortunately–Unfortunately*-methode komt oorspronkelijk uit improvisatietheater. Het is een techniek waarbij een verhaal zich afwisselend positief en negatief ontwikkelt. Elke nieuwe stap begint met “Fortunately...” (gelukkig/positieve tegenmaatregel) of “Unfortunately...” (helaas/risico’s) en verandert zo het verloop van het verhaal. Dit zorgt ervoor dat gebruikers verschillende scenario’s verkennen en onverwachte wendingen ontdekken.

VOORBEELD:



In de context van dit onderzoek zijn er nog een paar definities toegevoegd:

- Een unfortunately-node zonder fortunately kinderen is een **Weakness**. (zie node [7] in bovenstaand voorbeeld)
- Een unfortunately-node met bestaande uitwerkingen (kinderen), maar die nog moet worden herbekeken of verder verfijnd, wordt aangeduid als een **Weakness Under Review**. (zie node [4] in bovenstaand voorbeeld)
- Een fortunately-node met kinderen, maar waarvan de uitwerking nog herbekeken of verfijnd worden, krijgt de status van een **Assumption Under Review**. (zie node [3] in bovenstaand voorbeeld)
- Een fortunately-node waarvan de uitwerking in orde is en dus ook geen kinderen heeft, krijgt de status van een **Verified Assumption**. (zie node [5] in bovenstaand voorbeeld)

- De **danger rating** is een classificatie van een unfortunately-node om het niveau van gevaar uit te drukken. Het is een relatief getal dat bijvoorbeeld berekend kan worden op basis van likelihood en impact.

Je zal aan de hand van twee scenario's beide varianten van de software testen. Open nu versie 1/versie 2 van de software en bekijk de software even. Begin hierna aan het eerste scenario.

Story 1

Je werkt binnen een softwareteam dat bezig is met het uitwerken van een securitymodel voor een inlog- en authenticatiesysteem. Een deel van het team heeft al een begin gemaakt van een *Fortunately–Unfortunately*-model.

Het model is echter nog onvolledig en sommige delen moeten aangevuld of herbekeken worden. Het is jouw taak om het bestaande model verder te verkennen, aan te vullen en te verfijnen.

Taak 1:

Bij het controleren van de tree merk je dat er nog een *unfortunate* ontbreekt: een weakness/risico dat nog niet in het model is opgenomen, namelijk “*Sommige werknemers weigeren wachtwoordmanagers te gebruiken*”. Voeg dit negatieve scenario toe onder de node “*Uitrol van wachtwoordmanager verbetert gebruiksgemak*”. “Dit was de laatste unfortunately node in deze tak. Omdat deze unfortunately node gezien wordt als “*Not Important*” mag je deze status erbij zetten en mag de bovenliggende unfortunately-node beschouwd worden als “*Verified*”.

Taak 2:

Er wordt nu binnen het team verder nagedacht over een authenticatieprovider. Zoek de correcte plaats in de tree (namelijk: “*Provider-storingsen kunnen alle werknemers buitensluiten*”) en voeg de volgende nodes toe:

1. Fortunately: “*Team richt on-prem fallback-authenticatieserver in*”
2. Unfortunately: “*On-prem fallback synchroniseert credentials vertraagd*”
 1. Likelyhood: 4
 2. Impact: 3
 3. Danger Rating: $4 \times 3 \Rightarrow 12$
3. Fortunately: “*Periodieke synchronisatie en monitoring toegevoegd*”

Taak 3:

Nadien vraagt je teamlead naar een korte statusupdate om een inschatting te maken van de benodigde tijd. Zoek de volgende informatie:

1. De verified assumptions die het model bevat.

2. De weaknesses. Rangschik deze op basis van de dangerrating van hoogste naar laagste rating.
3. Hoeveel weaknesses under review or nog aanwezig zijn.
4. De assumptions under review.

Taak 4:

Tot slot moeten de verantwoordelijkheden verdeeld worden binnen het team. Selecteer twee elementen in de tree die eindigen op een *verified assumption* (groene eindnode). Gebruik de volledige fortunately/unfortunately-keten om samen te vatten welke stappen nodig zijn voor implementatie.

User experience questionnaire

Vul na het oplossen van de taken de user experience questionnaire in. Wanneer je hiermee klaar bent, mag je versie 1/versie 2 van de software openen en kort de software bekijken. Begin hierna aan het tweede scenario.

Story 2

Je zit in een softwareteam dat werkt aan een AI-systeem om fraude te detecteren. Er is al een begin gemaakt met een *Fortunately–Unfortunately*-model, maar het is nog niet compleet en sommige onderdelen moeten verder uitgewerkt worden.

Taak 1:

Voor je begint aan het verder uitwerken van de tree, wil je verkennen hoever ze voorlopig al staan. Lijst de volgende informatie op:

1. De weaknesses.
2. De verified assumptions.
3. De weaknesses under review.
4. Hoeveel assumptions under review er zijn.
5. De gevaarlijkste weakness.

Taak 2:

Bij de gevaarlijkste weakness merk je dat er nog iets ontbreekt. Zonder dit kan, zoals al aangehaald in de tree, er “*gevoelige modellogica aan interne medewerkers*” gelect worden. Voeg de ontbrekende nodes toe aan deze weakness.

1. “*Toegang wordt beperkt tot geverifieerde accounts [Assumption Under Review]*”
2. “*Accountbeheer veroorzaakt administratieve overhead [Weakness Under Review]*”
 1. Likelyhood: 5
 2. Impact: 2
 3. Danger rating: $5 \times 2 \Rightarrow 10$
3. “*Self-service accountbeheer vermindert werklast voor IT-support [Verified Assumption]*”

Alles voor deze piste is toegevoegd. Noteer of markeer bij de laatste fortunately node dat dit een “*Verified Assumption*” is.

Taak 3:

Je ziet nog een tak die je wilt bespreken met je collega's in de volgende vergadering, namelijk “*Junior teamleden besluiten alle servers uit te schakelen om fraude te stoppen*”. Deze node is incorrect en hoort ook niet onder de classificatie van een fortunately node. Omdat je dit eerst wil bespreken, wil je nog geen aanpassingen doen. Zoek wel de node op en documenteer de keten van nodes vanaf de root tot aan deze specifieke node.

Taak 4:

Daarnaast vraag je je af wat er gebeurt als we het AI fraudedetectiesysteem simpelweg afstemmen om minder false negatives te hebben. Dit noteren in de tree, maakt het mogelijk om hierover te brainstormen binnen het team. Zoek de node “*Hoge false positives blokkeren legitieme gebruikers*” en voeg onderstaande nodes onder elkaar toe:

1. Fortunately: “*Model afgestemd om gemiste fraude te verminderen*”
2. Unfortunately: “*Het terugdringen van false negatives leidt tot meer false positives*”
3. Fortunately: “*Risicogebaseerde scoring helpt om urgente en laag-risico waarschuwingen te onderscheiden*”

User experience questionnaire

Vul na het oplossen van de taken de user experience questionnaire in. Wanneer je hiermee klaar bent, mag je de open vragen beantwoorden.

Open vragen

Aan de hand van de volgende vragen, is het doel de toevoegingen ten opzichte van de basissoftware te bespreken.

1. Was de Fortunately-Unfortunately methode duidelijk?

2. Rankschik de features van meest nuttig (1) naar minst nuttig (8)? Als je een feature niet opgemerkt hebt, mag je deze een score van -1 geven.
 - ☐ Classificering door het schild icoon
 - ☐ Weergave van soort node door de kleur
 - ☐ Filtering op basis van de status van de node
 - ☐ Notitie van altijd nodes per bepaalde status
 - ☐ Rangschikking op basis van dangerrating binnen de filtering
 - ☐ Klikken van node in filtering balk highlight node
 - ☐ Samenvatting van root tot aan geduide node
 - ☐ Tooltips bij hoveren

3. Welke onderdelen van versie 1/versie 2 van de software zouden volgens jou verbeterd kunnen worden?

4. Heb je suggesties om features op een andere manier aan te pakken of een feature die nog nuttig kan zijn om de user experience te verbeteren?
5. In welke versie van de software vond je het makkelijker om de taken uit te voeren? Waarom?
6. Welke versie zou je in een echte situatie verkiezen en waarom?